

INFORMATION SECURITY SELF-ASSESSMENT REPORT

Platform Security Controls — Independent Internal Review

Ref: ALSH-SEC-2026-001 | Version 1.0 | May 12, 2026 | CONFIDENTIAL

Document Title	Information Security Self-Assessment Report
Reference	ALSH-SEC-2026-001
Version	1.0 — Initial Assessment
Assessment Date	May 12, 2026
Scope	Alshumookh API Platform — https://api.alshumookh-pay.com
Prepared By	Technology & Compliance — Alshumookh Global Banking Finance & Credit
Reviewed By	Ahmed Mohamed — Chief Executive Officer
Framework Ref	ISO/IEC 27001:2022, NIST CSF 2.0, OWASP API Security Top 10
Classification	CONFIDENTIAL

This self-assessment has been prepared by the Company's Technology & Compliance team as an internal control review. It is not a substitute for a third-party audit but provides a structured, evidence-based evaluation of the platform's security posture against recognised international frameworks.

1

EXECUTIVE SUMMARY

Alshumookh Global Banking Financing and Credit has conducted a comprehensive internal security assessment of its API-to-API digital asset settlement platform. The assessment covers access control, authentication, data protection, network security, operational security, and incident response against the ISO/IEC 27001:2022 and NIST CSF 2.0 frameworks.

Assessment Domain	Controls Evaluated	Pass	Partial	Planned
Access Control & Authentication	10	10	0	0
Data Protection & Encryption	8	8	0	0
Network & API Security	9	8	1	0
Operational Security & Logging	7	7	0	0
Incident Response	6	5	1	0

Assessment Domain	Controls Evaluated	Pass	Partial	Planned
Third-Party & Vendor Risk	5	5	0	0
Compliance & Governance	6	4	0	2
TOTALS	51	47	2	2

Overall Security Posture: **STRONG** — 47 of 51 controls fully implemented. 2 controls partially implemented (formal policies in draft). 2 controls planned (third-party certifications — SOC 2 / ISO 27001 audit).

2

ACCESS CONTROL & AUTHENTICATION

Control	Implementation	Evidence	Result
Multi-factor API authentication	API Key + HMAC + OAuth2 + JWT — all implemented	Code: payloads.py, oauth.py	✓ Pass
OAuth 2.0 client_credentials	POST /oauth/token — client_credentials grant	Code: oauth.py	✓ Pass
HMAC-SHA256 payload signing	X-Signature enforced per client flag	Code: payload_service.py	✓ Pass
JWT / JWS verification	RS256/HS256 via PyJWT, detached JWS	Code: payload_service.py	✓ Pass
mTLS fingerprint verification	X-Client-Cert-Fingerprint at app layer	Code: payloads.py	✓ Pass
API key rotation capability	Admin endpoint for key rotation implemented	Admin dashboard	✓ Pass
IP whitelist per client	Per-client IP ranges enforced at gateway	Code: WAF middleware	✓ Pass
Admin session authentication	Admin API key + session management	Code: admin.py	✓ Pass
Principle of least privilege	Client keys scoped to ingest only; admin keys issuance procedure	Key rotation procedure	✓ Pass
Replay attack protection	X-Timestamp ±5 min + Idempotency-Key	Code: payload_service.py	✓ Pass

3

DATA PROTECTION & ENCRYPTION

Control	Implementation	Evidence	Result
TLS 1.3 in transit	HTTPS enforced — TLS 1.3 on production domains	Ssl Labs scan	✓ Pass
HSTS header	max-age=31536000 on all responses	Security middleware	✓ Pass
Database encryption at rest	PostgreSQL with provider-level encryption (Render)	Render dashboard config	✓ Pass
Secrets management	All secrets in encrypted environment variables	Render env config — redacted	✓ Pass
No sensitive data logging	Audit logs exclude keys, secrets, card data	Code: audit_service.py	✓ Pass
CORS restricted origins	CORS_ALLOWED_ORIGINS — approved domains only	Code: origin.py	✓ Pass
CSP & security headers	CSP, X-Frame-Options, X-Content-Type-Options	Security middleware	✓ Pass
Webhook payload signing	All outbound webhooks HMAC-signed	Code: webhooks.py	✓ Pass

4

NETWORK & API SECURITY

Control	Implementation	Evidence	Result
WAF — path probe detection	Suspicious paths auto-blocked + IP banned	Code: WAF middleware	✓ Pass

Control	Implementation	Evidence	Result
Rate limiting	Per-IP rate limits enforced at middleware layer	Code: WAF middleware	✓ Pass
User-agent classification	Bot / scanner agents classified and blocked	Code: WAF middleware	✓ Pass
IP auto-ban on abuse	Repeated violation IPs auto-banned	Code: WAF middleware	✓ Pass
Input validation	Pydantic schema validation on all ingest endpoints	Code: payloads.py	✓ Pass
On-chain TX verification	Alchemy RPC verifies hash, wallet, amount, asset	Code: alchemy_service.py	✓ Pass
Idempotency enforcement	Duplicate sender_reference rejected with 409	Code: payload_service.py	✓ Pass
Health check access control	Health endpoint restricted by IP or token	Code: main.py	✓ Pass
Formal pen test	Third-party pen test commissioned — in progress	Engagement letter	Partial

5

OPERATIONAL SECURITY & LOGGING

Control	Implementation	Evidence	Result
API request audit logging	All ingest requests logged with timestamp, IP, key	Code: audit_service.py	✓ Pass
Security event logging	WAF events, auth failures, anomalies logged	Code: WAF middleware	✓ Pass
Admin operation logging	All admin actions recorded with actor and timestamp	Code: admin.py	✓ Pass
Reconciliation engine	POST /admin/reconcile — full per-payload audit	Code: reconciliation.py	✓ Pass
Health monitoring	Platform health check endpoint + uptime monitoring	Render dashboard	✓ Pass
Log retention	Logs retained in PostgreSQL — 5-year policy	Retention policy doc	✓ Pass
Signed webhook callbacks	Alchemy / Coinbase / MoonPay webhooks HMAC-verified	Code: webhooks.py	✓ Pass

6

INCIDENT RESPONSE

Control	Implementation	Status	Result
Incident detection capability	WAF + audit logs + anomaly detection in place	Implemented	✓ Pass
Security event alerting	Admin notified on critical security events	Implemented	✓ Pass
Auto IP ban on attack detection	Automated response to scanning/probing attacks	Implemented	✓ Pass
Incident response procedure	Documented IR procedure — CEO + tech lead	Implemented	✓ Pass
Rollback / recovery capability	Render rollback + database restore available	Implemented	✓ Pass
Formal IR runbook	Detailed runbook with timelines — in draft	Partial	Partial

7

THIRD-PARTY & VENDOR RISK

Vendor	Service	Security Status	Risk Level
MoonPay International	Payment links & fiat on-ramp	PCI DSS L1 certified	Low
Alchemy	Ethereum/Base RPC & webhook delivery	SOC 2 Type II	Low
Render	API platform hosting & deployment	SOC 2 Type II	Low



Vendor	Service	Security Status	Risk Level
Coinbase Commerce	Digital asset payment alternative	Regulated US entity	Low
PostgreSQL (managed)	Production database	Encrypted at rest	Low

8

ASSESSMENT CONCLUSION & SIGN-OFF

This security self-assessment demonstrates that Alshumookh Global Banking Financing and Credit operates a well-controlled and security-mature API platform. 47 of 51 evaluated controls are fully implemented and evidenced. The remaining 4 items are actively being addressed through third-party certification engagement. This report may be shared with counterparties as evidence of the Company's information security posture.

Assessed By	Technology & Compliance Team
Reviewed By	Ahmed Mohamed — Chief Executive Officer
Company	Alshumookh Global Banking Financing and Credit
Date	May 12, 2026
Next Assessment	May 2027 or upon material change to platform architecture
Framework	ISO/IEC 27001:2022 NIST CSF 2.0 OWASP API Security Top 10

END OF SECURITY SELF-ASSESSMENT REPORT · ALSHUMOOKH GLOBAL BANKING FINANCE & CREDIT · CONFIDENTIAL